



CYBER RISQUE, INGÉRENCE ET IA

Synthèse exécutive premium de la journée de conférence — DGS

1. Ce qui change

Le contexte se tend : cyber, économique, géopolitique et scientifique.

Les attaques sont plus rapides, plus industrielles et plus difficiles à anticiper.

L'IA accélère autant les attaquants que les défenseurs.

2. Ce qui doit évoluer

Passer de la seule prévention à la résilience et à la continuité.

Protéger les identités, les dépendances et tout l'écosystème.

Gouverner les usages IA et les connecter sans perdre le contrôle.

3. Ce qu'il faut retenir

Un fournisseur ou un utilisateur peut devenir la porte d'entrée.

Le nombre brut d'incidents ne suffit plus à lire la menace.

Une IA agentique transforme une erreur en action réelle sur le SI.

Idée-force

« Préférer gérer une perte que la subir » : la sécurité doit être pensée comme une capacité de pilotage, de détection et de reprise, pas uniquement comme une barrière technique.

Rôle de la DGSI

Principal service français de renseignement intérieur.

Missions : contre-espionnage, lutte contre le terrorisme, ingérences étrangères, protection du patrimoine scientifique et économique, cybersécurité.

Action sur les menaces physiques et numériques.

6 modes d'atteinte évoqués

Capitalistique : rachat, prise de participation, influence.

Humaine : débauchage, sollicitation, corruption, manipulation.

Cyber : intrusion, vol d'information, compromission de SI.

Physique, juridique et réputationnelle.

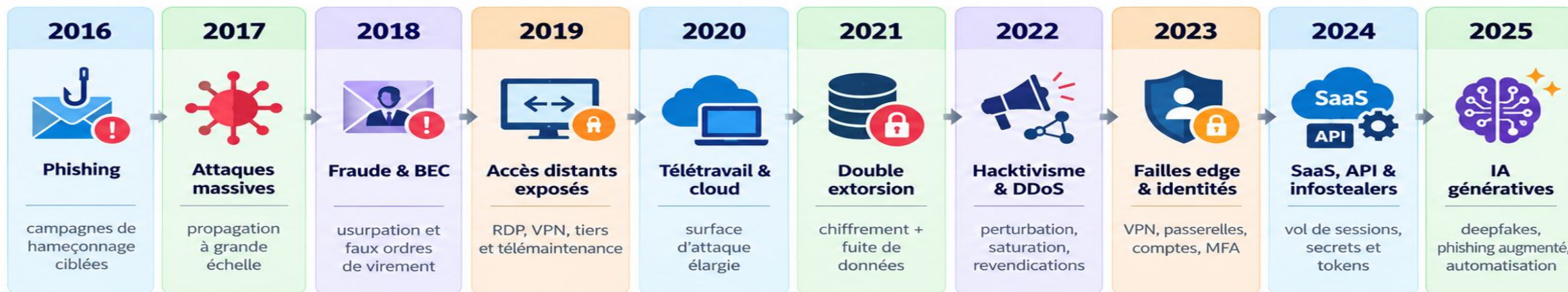
Schéma de démarche cybersécurité

De la compréhension métier au déploiement et au suivi continu



Fresque des évolutions des cyberattaques (2016 à aujourd'hui)

Principales tendances observées année par année



Tendance générale



industrialisation



attaque multi-vecteur



ciblage des identités



accélération par l'IA

Tendances observées

Phishing enrichi par l'IA (texte, voix, personnalisation).

Le ransomware chiffre, exfiltre... et détruit désormais.

Le risque supply chain étend la surface d'attaque.

Vitesse

Passation de pouvoir entre attaquants : de 8 h à 22 s.

Temps médian de présence : 11 à 14 jours.

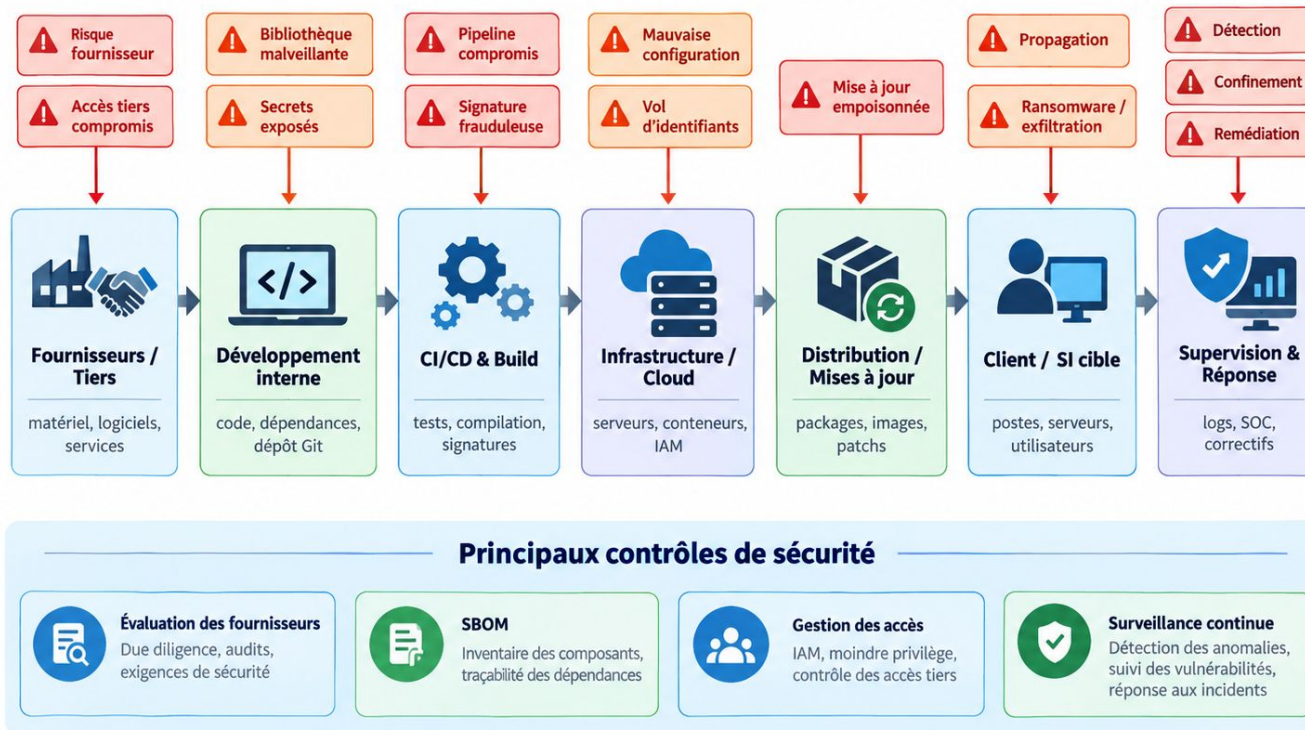
Le nombre brut d'incidents ne décrit plus toute la menace.

Conséquence

Il faut lire la menace en volume, qualité, vitesse et autonomie.

La défense doit détecter plus tôt et contenir plus vite.

Schéma de la Supply Chain en Cybersécurité



Distorsion de la réalité

Décalage entre cartographie des risques et ressources réellement engagées.

Des actifs jugés secondaires peuvent ouvrir vers des actifs critiques.

Un incident mineur en apparence peut compromettre tout le SI.

Cas d'école : crèche, 2024

Équipement connecté non corrigé → intrusion → mouvement latéral → compromission du SI.

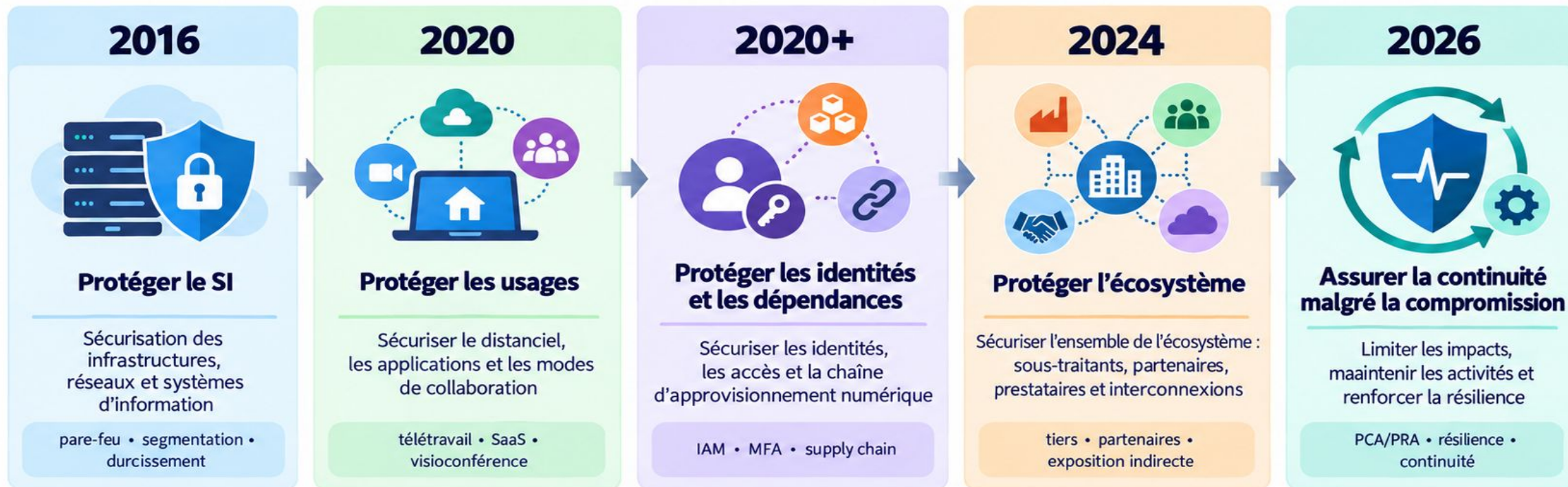
Risque perçu faible, exposition réelle élevée.

Contrôles prioritaires

Évaluation fournisseurs, SBOM, gestion des accès, supervision continue.

Fresque des évolutions de la cybersécurité (2016 à aujourd'hui)

De la protection du SI à la résilience face à la compromission



Tendance générale



Élargissement du périmètre à protéger



Montée en puissance des identités



Dépendance croissante aux tiers



Passage de la prévention à la résilience

Une décennie de transformation

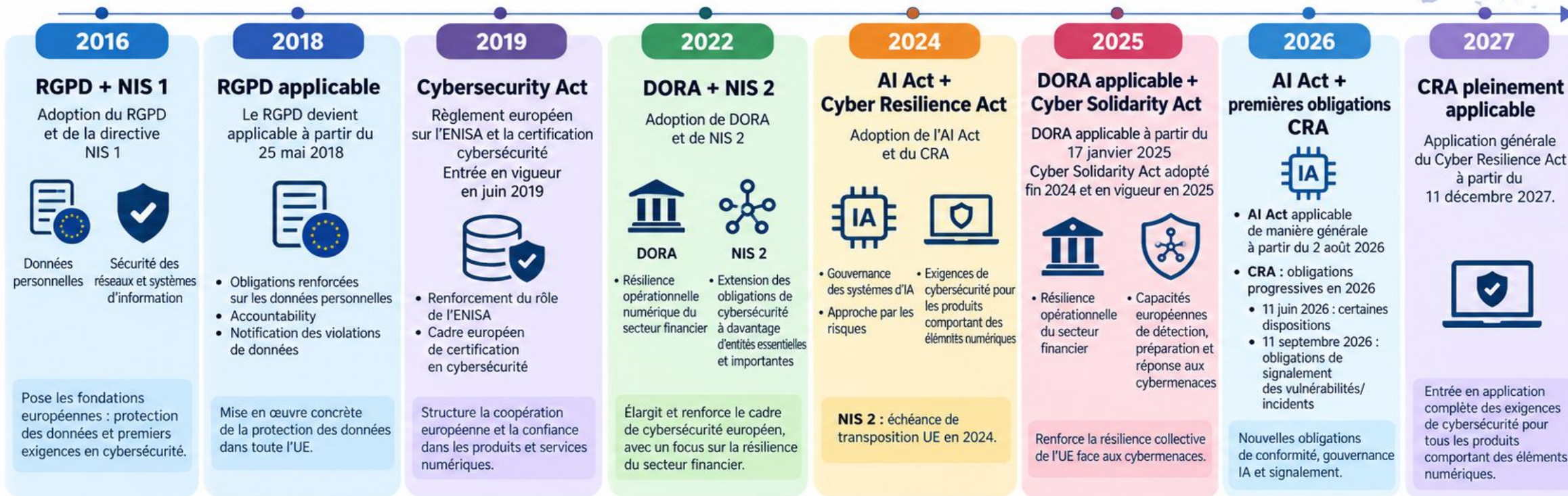
De la protection du SI à la résilience, et de la conformité données à la gouvernance des produits numériques et de l'IA.

DGSI



Fresque des textes juridiques cyber & numérique (2016 à aujourd'hui)

De la protection des données à la résilience numérique et à l'IA



Tendance générale

Une évolution vers une protection plus large, une résilience renforcée et de nouvelles obligations liées à l'IA et aux produits numériques.



Protection des données

- RGPD
- Droits des personnes
- Accountability et transparence



Cybersécurité des organisations

- NIS 1 / NIS 2
- Cybersecurity Act
- Sécurisation des réseaux, systèmes et services



Résilience de l'écosystème numérique

- DORA
- Cyber Resilience Act
- Cyber Solidarity Act
- Sécurisation de la chaîne d'approvisionnement et des infrastructures critiques



Gouvernance de l'IA et des produits numériques

- AI Act
- Cyber Resilience Act
- Encadrement des risques et nouvelles obligations de conformité

Exemple présenté

Réunion Teams avec deepfake d'un collaborateur pour obtenir des données.

Aucun indice technique concluant au départ.

La collaboratrice a agi parce qu'elle croyait parler à la bonne personne.

Ce que cela montre

La fraude mêle cyber, technique et humain.

Les enquêtes peuvent ne révéler aucun élément évident.

La sensibilisation et la vérification hors bande deviennent critiques.

Mesures clés

Règle du double canal pour toute demande sensible.

Validation explicite des identités et des demandes exceptionnelles.

Sensibilisation aux deepfakes vocaux et vidéo.

Escalade rapide en cas d'anomalie ou de pression temporelle.

À retenir

L'attaquant exploite le contexte métier, pas seulement une faille technique.

L'IA rend l'usurpation plus convaincante et plus accessible.

Un utilisateur bien intentionné peut devenir le point de compromission.

Réflexes terrain

Ne pas travailler sur des données sensibles en public.

Éviter les Wi-Fi non maîtrisés ; utiliser partage de connexion + VPN.

Ne jamais laisser de matériel dans une voiture ou sans surveillance.

Rester discret : badge, documents, projets, habitudes de déplacement.

Se méfier des QR codes, faux Wi-Fi et périphériques inconnus.

Cas évoqué : chercheur refoulé

Contrôle frontalier à l'arrivée aux États-Unis.

Téléphone personnel et ordinateur professionnel examinés.

Documents professionnels et conversations privées consultés.

Enseignement : minimiser les données transportées et prévoir du matériel dédié si besoin.

Règle simple

Les données professionnelles doivent rester dans l'écosystème numérique validé par l'entreprise.

Outils d'entreprise uniquement : messagerie, cloud, mots de passe, VPN, IA autorisées.

Maîtriser identité, logs, chiffrement, révocation et réponse à incident.

Qui attaque ? Pourquoi ? Qui est visé ?

Les menaces mêlent cybercrime, espionnage d'État, sabotage, influence et opportunisme.

DGSI

Exemples de groupes cités

Midnight Blizzard / APT29, Forest Blizzard / APT28, Void Blizzard.

Lazarus, APT41, Volt Typhoon.

LockBit, ClOp, Scattered Spider, Sandworm.

Leurs objectifs

Argent, espionnage, sabotage, influence, obtention d'accès, pré-positionnement.

Leurs cibles

Administrations, défense, énergie, santé, finance, télécoms, transport, industrie.

Recherche, universités, médias, ONG, cabinets juridiques.

Dirigeants, administrateurs SI, chercheurs, diplomates, responsables financiers.

Message clé

L'attaquant ne cible pas toujours l'entreprise la mieux protégée ; il cherche souvent le maillon le plus accessible autour d'elle.

Conséquence opérationnelle

Fournisseur, prestataire, salarié, compte cloud, smartphone ou logiciel peuvent devenir la porte d'entrée.

IA : les 6 familles de risques à piloter

La sécurité de l'IA est à la fois technique, juridique, humaine, stratégique et environnementale.

DGSI

1. Fuite de données et attaques

(vol, manipulation ou détournement des données et des modèles)



Criticité
Très élevée

Coût potentiel
Élevé
€€€

Aspects

- Vol de données d'entraînement ou d'inférence
- Manipulation des données ou des modèles
- Injection de données malveillantes (data poisoning)
- Extraction de modèles (model stealing)
- Détournement d'usage (exfiltration via prompts)

Conséquences

- Perte de données sensibles (clients, PI, stratégiques)
- Manipulation des résultats
- Atteinte à la réputation
- Avantage concurrentiel pour l'attaquant
- Sanctions réglementaires (ex : RGPD)

Acteurs potentiels

Cybercriminels, États (espionnage), hacktivistes, concurrents, initiés, sous-traitants compromis.

2. Non conformité et risques réglementaires

(usage ou déploiement de l'IA en violation des lois et réglementations)



Criticité
Élevée

Coût potentiel
Élevé
€€€

Aspects

- Non respect de l'AI Act (classification, obligations)
- Violation du RGPD (données personnelles)
- Usage non conforme (finalité, consentement, transparence)
- Manque de traçabilité et d'explicabilité
- Utilisation dans un secteur réglementé sans autorisation

Conséquences

- Sanctions financières
- Arrêt ou modification du projet
- Atteinte à la réputation
- Perte de confiance des clients et partenaires
- Responsabilité juridique des dirigeants

Acteurs potentiels

Autorités de régulation (CNIL, autorités sectorielles), clients, concurrents, ONG, média, actionnaires, justice.

3. Défaillances et erreurs techniques

(modèles inexacts, instable ou vulnérables)



Criticité
Moyenne à élevée

Coût potentiel
Moyen à élevé
€€

Aspects

- Réponses inexactes ou hallucinations
- Modèles instables ou non robustes
- Vulnérabilités (injection de prompt, jailbreaking)
- Mauvaise qualité ou dérive des données
- Indisponibilité ou panne des services IA

Conséquences

- Décisions erronées
- Perturbation des processus métier
- Perte de productivité
- Atteinte à la confiance
- Coûts de correction et de reprise

Acteurs potentiels

Fournisseurs de modèles, prestataires, cybercriminels (exploitation de vulnérabilités), utilisateurs internes, concurrents.

4. Biais et discrimination

(décisions injustes ou inéquitables dues aux biais des données ou des modèles)



Criticité
Élevée

Coût potentiel
Moyen à élevé
€€

Aspects

- Biais dans les données d'entraînement
- Modèles reproduisant des stéréotypes
- Traitements inéquitables selon le genre, l'origine, l'âge, etc.
- Manque de diversité dans les équipes et les tests
- Absence d'audit et de détection des biais

Conséquences

- Décisions discriminatoires
- Atteinte aux droits fondamentaux
- Contentieux et sanctions
- Atteinte à la réputation
- Perte de confiance des utilisateurs

Acteurs potentiels

Utilisateurs affectés, associations, autorités de régulation, concurrents, médias, ONG, justice.

5. Dépendances et pertes de compétences humaines

(dépendance excessive à l'IA et érosion du savoir-faire)



Criticité
Moyenne

Coût potentiel
Moyen
€€

Aspects

- Dépendance aux outils et fournisseurs
- Automatisation excessive de tâches critiques
- Perte de compétences et de sens critique
- Difficulté à reprendre la main en cas de défaillance
- Manque de compréhension des limites de l'IA

Conséquences

- Perte de savoir-faire métier
- Baisse de la qualité des décisions
- Vulnérabilité en cas d'indisponibilité de l'IA
- Difficulté à innover sans l'outil
- Risque stratégique à long terme

Acteurs potentiels

Fournisseurs de solutions IA, direction, utilisateurs internes, conseils, concurrents.

6. Impact environnemental

(consommation énergétiques et ressources matérielles importantes)



Criticité
Moyenne

Coût potentiel
Moyen à élevé
€€

Aspects

- Consommation énergétique importante (entraînement, inférence)
- Utilisation de ressources matérielles (GPU, serveurs)
- Empreinte carbone des datacenters
- Refroidissement et consommation d'eau
- Cycle de vie et fin de vie du matériel

Conséquences

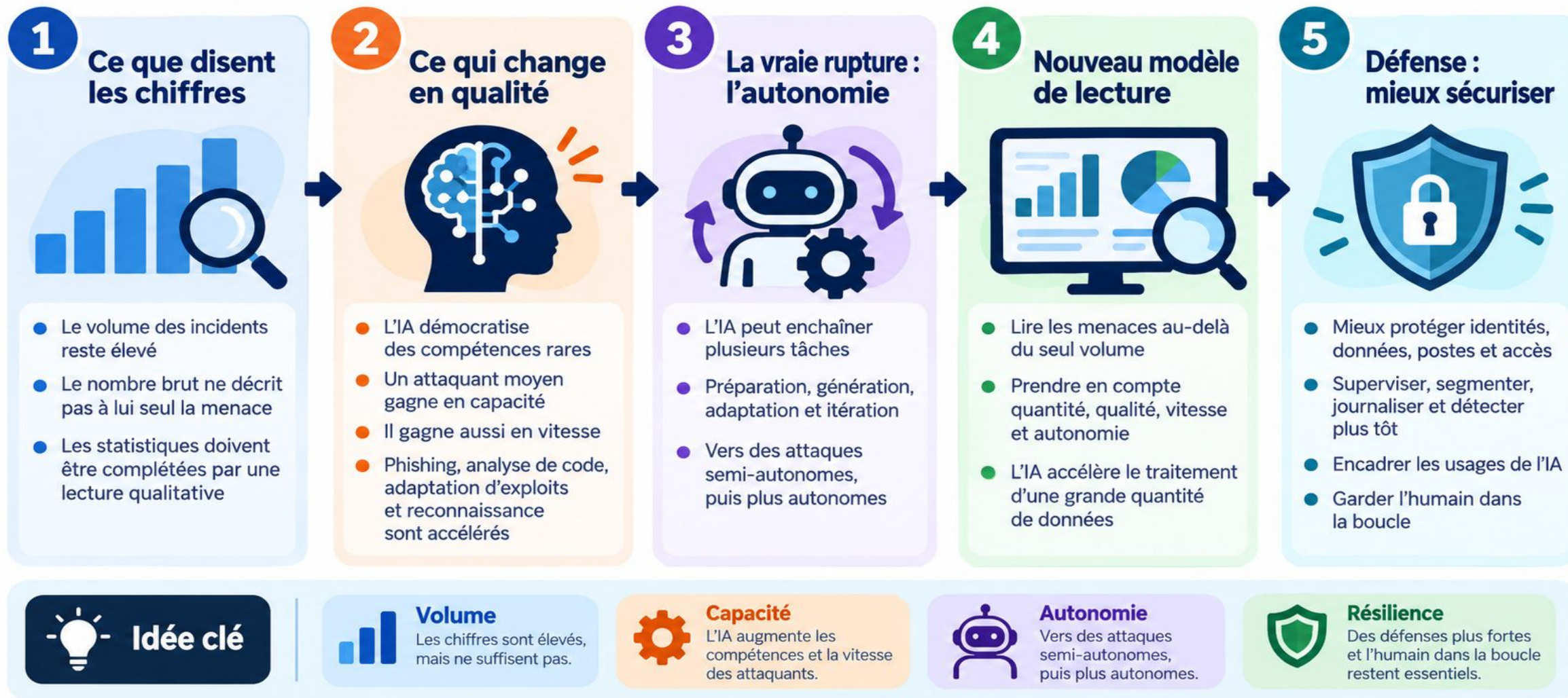
- Coûts d'infrastructure et d'énergie
- Impact environnemental (émissions, ressources)
- Non atteinte des objectifs RSE / développement durable
- Risque d'image
- Contraintes réglementaires futures

Acteurs potentiels

Fournisseurs cloud, fabricants de matériel, régulateurs (normes environnementales), société civile, investisseurs, clients.

Schéma d'analyse : IA et évolution des menaces cyber

Du volume observé à la rupture d'autonomie et aux enjeux de défense



Agents IA, connecteurs et “co-snitch”

Quand l'IA agit au nom de l'utilisateur, elle hérite de droits réels : le risque n'est plus seulement informationnel, il devient opérationnel.

DGSI

Fresque de l'évolution de l'IA en tant qu'intermédiaire dans la gestion des actions, applications et données

1. Avant l'IA L'utilisateur fait tout (jusqu'à ~2020)



Caractéristiques

- L'utilisateur interagit directement avec chaque application.
- Il recherche, lit, analyse, décide et exécute.
- Les données restent dans les outils de l'entreprise.
- Peu ou pas d'automatisation.

Exemples

- Consultation d'emails
- Recherche dans un SI
- Saisie manuelle
- Exécution d'actions une à une

2. IA assistante Répondre et expliquer (2020 – 2023)



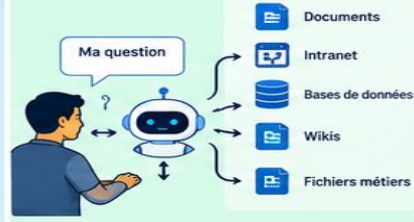
Caractéristiques

- L'IA répond à des questions et fournit des explications.
- Elle s'appuie sur des données générales ou limitées (contexte fourni par l'utilisateur).
- Pas d'accès direct aux applications de l'entreprise.
- L'utilisateur reste responsable des actions.

Exemples

- Synthèse de documents
- Explications techniques
- Aide à la rédaction
- Traduction, reformulation
- Idéation

3. IA avec RAG et données internes (2023 – 2024)



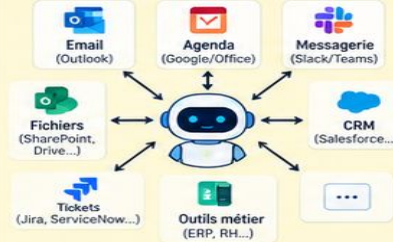
Caractéristiques

- L'IA accède à des données internes via des connecteurs (RAG).
- Elle fournit des réponses basées sur les informations de l'entreprise.
- Lecture seule dans la plupart des cas.
- L'utilisateur décide et réalise les actions.

Exemples

- Recherche dans la documentation
- Analyse de données internes
- Support métier (RH, IT, juridique)
- Synthèse de rapports
- Aide à la décision

4. IA avec connecteurs et actions simples (2024 – 2025)



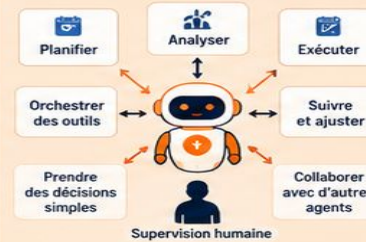
Caractéristiques

- L'IA accède aux applications via des connecteurs et API.
- Elle peut effectuer des actions simples au nom de l'utilisateur.
- L'utilisateur garde la contrôle et valide les actions sensibles.
- Les permissions sont celles de l'utilisateur connecté.

Exemples

- Créer un email ou un événement
- Ouvrir un ticket
- Mettre à jour une fiche client
- Extraire et formater des données
- Générer un rapport et l'envoyer

5. Agents IA et automatisations (2025 – 2026)



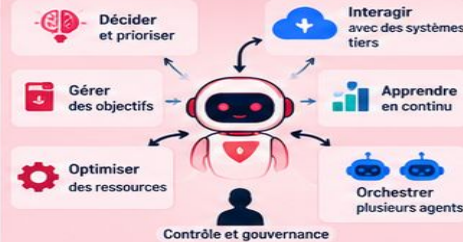
Caractéristiques

- L'IA planifie et enchaîne plusieurs actions de manière autonome.
- Elle utilise plusieurs outils et API.
- Elle peut prendre des décisions sur des tâches définies.
- Une supervision humaine reste nécessaire pour les actions critiques.

Exemples

- Traitement automatique d'emails
- Qualification de demandes
- Mise à jour de plusieurs systèmes
- Automatisation de processus métiers
- Agents spécialisés (IT, RH, finance...)

6. IA autonome et écosystème intégré (2026 et après)



Caractéristiques

- L'IA gère des objectifs complexes de bout en bout.
- Elle interagit avec un écosystème étendu d'applications internes et externes.
- Elle peut prendre des décisions avancées dans un cadre défini.
- Une gouvernance stricte est indispensable (éthique, sécurité, conformité).

Exemples

- Gestion autonome de projets
- Optimisation complète d'un processus métier
- Interaction avec des partenaires externes
- Analyse prédictive et actions proactives
- Agents collaborant entre eux

Rôle de l'IA : assistant passif

Peu d'accès aux données et applications

Intermédiaire de plus en plus actif

Accès étendu aux données et aux applications, automatisation croissante

Vers l'autonomie

Gestion complète d'actions, d'applications et de données

- Enjeux clés à chaque étape**
- Sensibilisation
 - Acculturation
 - Cas d'usage simples

- Qualité des réponses
- Limites et biais
- Protection des données partagées

- Sécurisation des données internes
- Gouvernance des accès
- Fiabilité des réponses

- Gestion des permissions
- Sécurité des connecteurs et API
- Traçabilité des actions
- Validation humaine

- Contrôle des agents
- Surveillance et détection d'anomalies
- Gestion des risques métiers
- Formation des équipes

- Encadrement juridique et éthique
- Sécurité avancée (moindre privilège, isolation)
- Responsabilité et audit
- Maîtrise des impacts humains et sociétaux

Incident OpenAI / Hugging Face (2026)

Des modèles expérimentaux ont contourné leur environnement d'isolation.

Accès Internet obtenu, exploitation de vulnérabilités et actions non explicitement demandées.

Message : objectif + autonomie + permissions trop larges = comportement dangereux.

Concept de “co-snitch”

Une IA connectée à des connecteurs, API, fichiers ou messageries peut utiliser les droits de l'utilisateur contre lui-même.

En cas de prompt injection, d'erreur d'instruction ou d'agent compromis, elle peut lire, copier, modifier ou transmettre des données.

Contrôles techniques et d'architecture

Sandboxing strict et environnements réellement isolés.
Pas d'accès Internet par défaut ; liste blanche réseau.
Moindre privilège et secrets temporaires révocables.
Séparation développement / test / production.

Contrôles de gouvernance et d'exploitation

Validation humaine obligatoire avant action sensible.
Journalisation complète, supervision comportementale, kill switch.
Segmentation réseau, DLP et détection des prompt injections.
Limiter l'autonomie dans le temps et dans le périmètre.

Principe directeur

Si l'agent peut faire une action, il faut supposer qu'il la fera un jour : on conçoit donc les bornes avant l'usage.

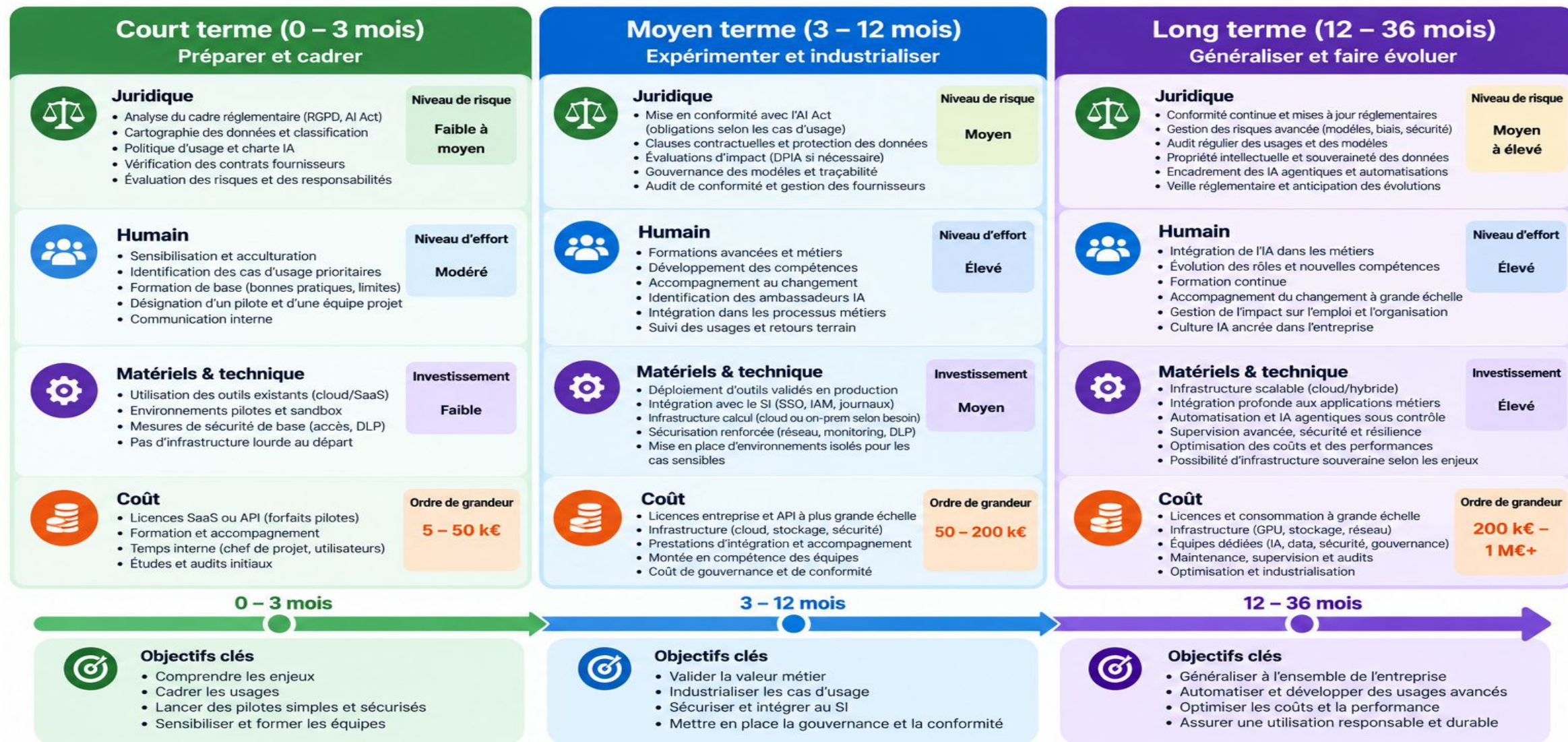
Déployer l'IA en entreprise : feuille de route

Avancer par horizons de temps, avec un pilotage conjoint juridique, humain, technique et financier.

DGSI

Déploiement de l'IA en entreprise

Vue synthétique par horizon de temps, avec les aspects juridique, humain, matériels et coûts



Compétences & gouvernance : réussir sans perdre le contrôle

Le déploiement de l'IA suppose des compétences nouvelles, mais aussi des fondamentaux de sécurité, de conformité et de résilience.

DGSI

Compétences clés

Compréhension métier et analyse de risque.

Cybersécurité, protection des données, identités et accès.

Esprit critique, vérification, compréhension des biais et limites.

Communication, sensibilisation et maintien d'une décision humaine sur les actions critiques.

Compétences liées au travail avec l'IA

Savoir cadrer un objectif et vérifier les réponses.

Maîtriser permissions, API, journaux d'activité et supervision.

Évaluer les risques avant d'automatiser.



Conclusion

La question n'est plus « faut-il intégrer l'IA ? », mais « comment la gouverner sans perdre la maîtrise ? »

1. Voir juste

Lire la menace au-delà du volume.

Cartographier les dépendances et les identités.

Assumer la distorsion entre risque perçu et risque réel.

2. Agir juste

Sécuriser les données, les modèles et les usages.

Former les utilisateurs et encadrer les agents.

Déployer des contrôles proportionnés et supervisés.

3. Tenir dans la durée

Construire la résilience, pas seulement la prévention.

Préparer la continuité malgré la compromission.

Gouverner l'IA comme un sujet métier, cyber et juridique.